build

看完文件之後確定了 vpc 跟 subnet 的關係。
具體設定是

- 我先建了一個 VPC 10.1.0.0/24，裡面有一個 subnet 10.1.0.0/28 (真正可用的是10.1.0.4 ~ 10.1.0.14 剩下的是VPC router、AWS DNS server 等等的)
- 然後我建了一個 IGW 設定所有的對外流量 (0.0.0.0/0) 會連出去，讓這個 subnet 變成可以連出去
- 然後 SG 設定
  - 只允許持有 SSH key 的來源通過 22 port
  - 對外 (egress) 則全部放行
- 還建了 IAM role，這樣就可以用 SSM 連進來
- EC2 用的是 AL2
- 建立的時候會跑一段 user data 腳本，裡面是安裝 docker 跑 Metabase v0.46.6，再把 container 裡的 3000 port 映射到 EC2 的 3000 port

建起來之後

```
Do you want to perform this update? yes
Updating (prod):
     Type                              Name                 Status
 +   pulumi:pulumi:Stack               5tmate-metabase-prod created (43s)
 +   ├─ aws:ec2:Vpc                    vpc                  created (13s)
 +   ├─ aws:iam:Role                   ssm-role             created (2s)
 +   ├─ aws:ec2:KeyPair                key                  created (1s)
 +   ├─ aws:iam:InstanceProfile        instance-profile     created (8s)
 +   ├─ aws:iam:RolePolicyAttachment   ssm-core             created (0.77s)
 +   ├─ aws:ec2:Subnet                 subnet               created (12s)
 +   ├─ aws:ec2:InternetGateway        igw                  created (2s)
 +   ├─ aws:ec2:SecurityGroup          ssh-sg               created (5s)
 +   ├─ aws:ec2:RouteTable             rt                   created (2s)
 +   ├─ aws:ec2:Instance               honeypot             created (14s)
 +   └─ aws:ec2:RouteTableAssociation  rt-assoc             created (1s)

Outputs:
    igw_id            : "igw-0326566aeb32aea2f"
    instance_id       : "i-0c85e2bb57030cd70"
    public_dns        : "ec2-13-230-197-64.ap-northeast-1.compute.amazonaws.com"
    public_ip         : "13.230.197.64"
    route_table_id    : "rtb-0e9f97a58542a135f"
    security_group_id: "sg-0659b8b80c6df7cdf"
    subnet_id         : "subnet-099ff2107fe2e8713"
    vpc_id            : "vpc-03ab0dc543aee3715"

Resources:
    + 12 created

Duration: 47s
```

本機可以 ssh 進去

```
# jerry in Jerry  ~ ❯ T5 ❯ 5tmate ❯ infra ❯ metabase on git:?feat/metabase-honeypot-ec2                    [17:31:43]
 255 → ssh -i ~/.ssh/id_ed25519 ec2-user@13.230.197.64
The authenticity of host '13.230.197.64 (13.230.197.64)' can't be established.
ED25519 key fingerprint is SHA256:xY0WoS6xBx9aJagQCSnB2Pw+CyedGqiE373Zd+0PdqY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '13.230.197.64' (ED25519) to the list of known hosts.
Enter passphrase for key '/home/jerry/.ssh/id_ed25519':
   ,     #_
   ~\_  ####_        Amazon Linux 2023
  ~~  \_#####\
  ~~     \###|
  ~~       \#/ ___   https://aws.amazon.com/linux/amazon-linux-2023
   ~~       V~' '->
    ~~~         /
      ~~._.   _/
         _/ _/
       _/m/'
[ec2-user@ip-10-1-0-14 ~]$
```

SSM 也可以進去

```
# jerry in Jerry  ~ ❯ T5 ❯ 5tmate                                                [17:41:23]
→ aws ssm start-session --target i-0c85e2bb57030cd70 --region ap-northeast-1

Starting session with SessionId: jerry.fang-2tjgggbzjzlzc5tnb66tca9yaq
sh-5.2$
```

打/api/session/properties 確實可以看到 setup-token

```
sh-5.2$ curl -s http://localhost:3000/api/session/properties | grep -o '"setup-token":"[^"]*"'
"setup-token":"9ee80ece-7bc3-4673-b1fb-a517ff5c251c"
sh-5.2$
```

在 EC2 裡面用 nuclei 掃，真的有洞

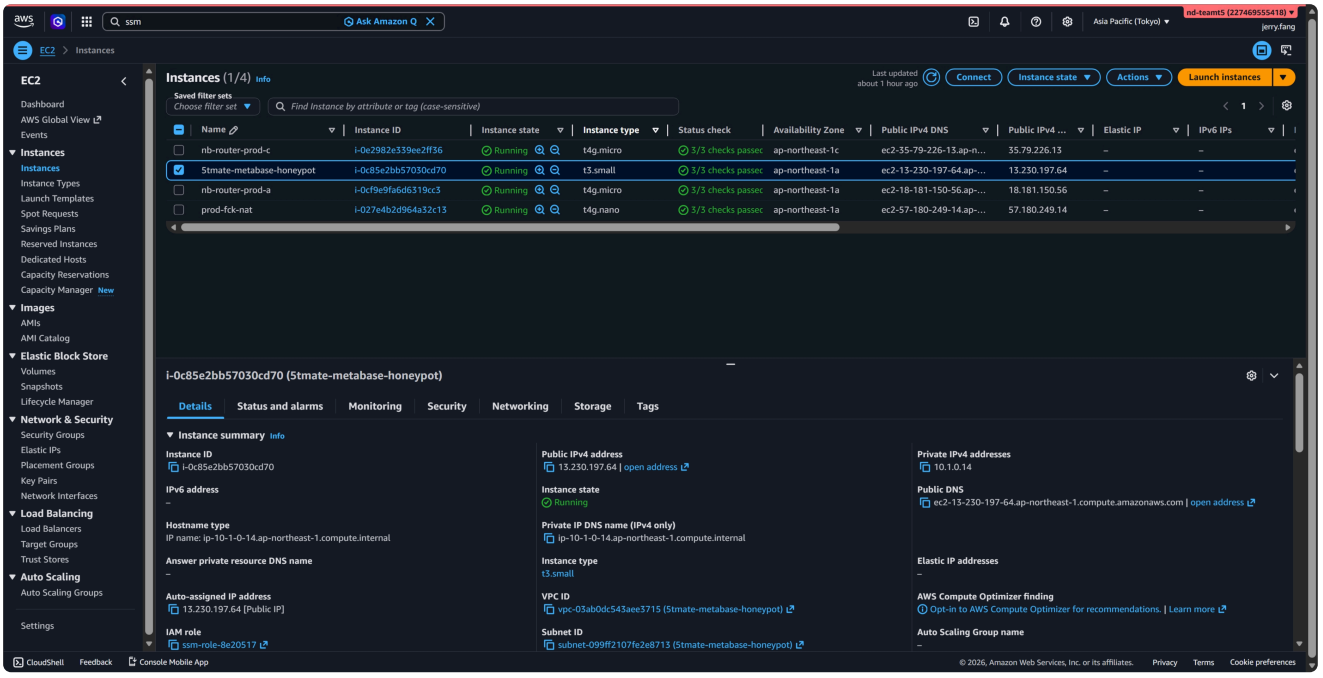
```
sh-5.2$ sudo docker run --rm --network host projectdiscovery/nuclei:latest \
    -u http://localhost:3000 -tags metabase
Unable to find image 'projectdiscovery/nuclei:latest' locally
latest: Pulling from projectdiscovery/nuclei
9b70e313681f: Pull complete
289b2719c35d: Pull complete
1aa944d3e15d: Pull complete
Digest: sha256:66b5f88c9b98ad29c03343dd34e5e85bde0ad10428d72e0171b067efe1ed7811
Status: Downloaded newer image for projectdiscovery/nuclei:latest


                     __     _
   ____  __  _______/ /__  (_)
  / __ \/ / / / ___/ / _ \/ /
 / / / / /_/ / /__/ /  __/ /
/_/ /_/\__,_/\___/_/\___/_/   v3.9.0

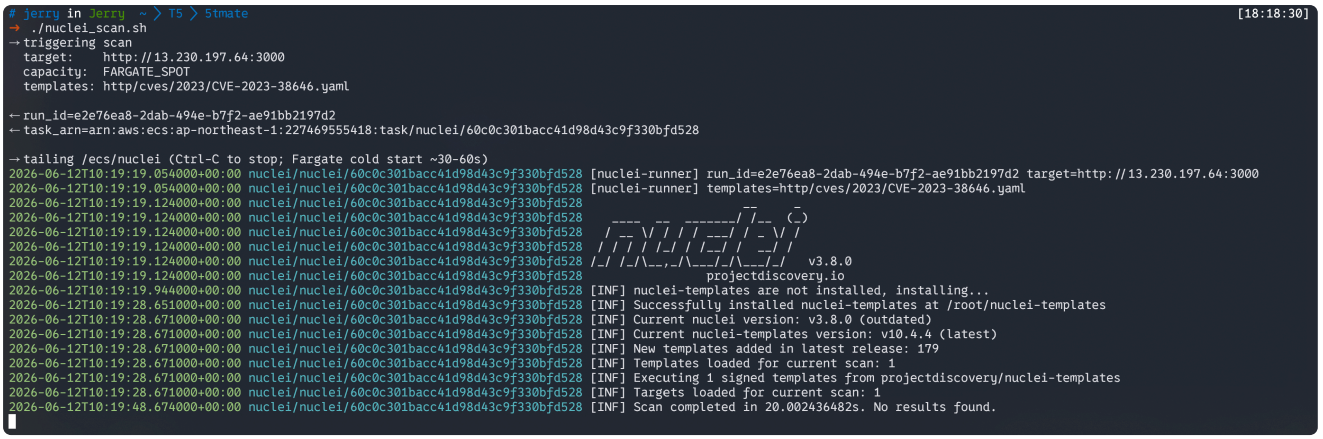
                projectdiscovery.io

[INF] nuclei-templates are not installed, installing...
[INF] Successfully installed nuclei-templates at /root/nuclei-templates
[WRN] Found 17 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.9.0 (latest)
[INF] Current nuclei-templates version: v10.4.4 (latest)
[INF] New templates added in latest release: 179
[INF] Templates loaded for current scan: 5
[INF] Executing 5 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[metabase-installer-exposure] [http] [high] http://localhost:3000/setup
[metabase-panel] [http] [info] http://localhost:3000/auth/login ["v0.46.6"]
[CVE-2023-38646] [http] [critical] http://localhost:3000/api/setup/validate
[INF] Using Interactsh Server: oast.pro
[INF] Scan completed in 5.914079422s. 3 matches found.
sh-5.2$
```

在本機嘗試用 nuclei 來試試看能不能摸到
先去看一下 EC2 的公網 IP



從本機掃，發現確實掃不到



小結

今天用 Pulumi 把整套隔離網路實際建起來，包含 VPC（10.1.0.0/24）+ 一個 subnet（10.1.0.0/28）+ IGW 讓 subnet 能對外，SG 只放行自己的 SSH 22、egress 全開，再加 IAM role 讓 SSM 能進，EC2 用 AL2 並在 user data 用 docker 跑 Metabase v0.46.6。建好後一一驗證，本機 SSH、SSM 都進得去，`/api/session/properties` 確實吐得出 setup-token，在 EC2 內用 nuclei 掃得到洞，但從本機（走公網 IP）掃卻完全掃不到，剛好符合對外不可見、對內真的有洞的目標。

參考資料

- How Amazon VPC works (VPC / subnet / route)
- Internet gateways - Amazon VPC
- Running Metabase on Docker
- projectdiscovery/nuclei